

ServerManager Security Code Review

Date: 4 October 2026 (updated)

Scope: VPS edge, portal auth, Ed25519 key-bound VPN trust circle, Flint LAN gate, USB key vault

Primary branch: cursor/keys-home-wifi-enroll-a9a6 (stacked on authenticator / media / harden work)

Classification: Operator security review - not a formal pentest report

1. Executive summary

This update revises the 3 Oct review after the key-required trust circle landed live on VPS 74.208.76.213. Circle membership is no longer "approve an IP and trust it forever": every non-sealed member must carry an Ed25519 public key bound to that IP, proven by Authenticator signatures. Keyless allowlist rows are scrubbed to pending and blocked on Flint before NAT.

What improved most (campaign + this update)

1. Key-bound circle - approve requires pubkey; scrub demotes keyless; sticky/Caddy/Flint only trust sealed or key-bound rows.
2. Crypto proofs - Authenticator sends X-SM-Circle-* headers; server verifies Ed25519 against the IP-bound key.
3. Campus egress deny - shared WAN 192.81.235.246 cannot enter the circle; LAN approve still works over OVPN PBR.
4. Edge hardeners - SSH rate caps, VPN-only admin UIs, Secure cookies, proxy-safe client IP for lockouts.
5. USB LUKS key vault - operator SSH keys on removable encrypted media (not HSM).

Residual risk (honest)

- USB LUKS is not YubiKey/TPM while unlocked.
- Circle state is still distributed (JSON + sticky + Flint + Caddy).
- Public SSH remains intentional break-glass.
- Guest VPN clients can ignore pushed DNS (raw-IP residual).

Composite posture: ~8.1/10 for opportunistic internet + curious LAN + lost USB; lower against malware-on-host-while-unlocked.

2. Architecture under review

Internet clients

```
|  
|- UDP 500/4500 IKEv2, WG, TCP 8443/443 OpenVPN -> VPS  
|- TCP 80/443 HTTPS (Caddy + sslh) -> VPS  
|- TCP 22 SSH (UFW limit) -> VPS
```

```
|  
Portal server.py + Authenticator APIs  
Ed25519 IP<->key bind + circle proofs
```

```
Caddy @vpn_clients + sticky key-bound /32s
Guest DNS for untrusted VPN VIPs
|
OpenVPN to Flint
|
Home LAN 192.168.8.0/24
Flint SM-LAN-CIRCLE pre-NAT
Proxmox / NAS / Plex / ...
```

```
Domain | Owners | Trust assumption
VPS edge | portal/scripts/security/harden-*.sh | World can knock; admin apps VPN+auth
Portal | portal/server.py | Session + 2FA + circle crypto
Circle identity | allowlist JSON, sticky, peer-acl | Sealed WAN OR key-bound IP only
Home LAN | ensure-lan-circle-flint-gate.sh | Pending/keyless blocked pre-NAT
Operator keys | usb-key-vault/ | Private keys on LUKS USB
```

3. Key-required trust circle (new)

3.1 Policy

Except sealed router WAN rows, an IP may not enter or remain in `allowed` without an Ed25519 `pubkey`. Sticky seeding from the Caddy sticky file alone is disabled so a leftover /32 cannot resurrect membership without a key.

3.2 Approve path (portal/server.py)

```
if action_n == "approve" and not _is_sealed_vpn_ip(ip_n) and not pub_n:
    raise ValueError(
        "Ed25519 public key required - circle membership is key-bound only "
        "(approve from Authenticator so a private/public key pair is created)"
    )
```

Campus / permanently denied WANs still cannot approve:

```
if _is_denied_vpn_ip(ip_n) and action_n == "approve":
    raise ValueError(
        "This shared campus/ISP egress IP is permanently denied ..."
    )
```

3.3 Scrub on read/write

```
def _scrub_allowlist_require_circle_keys(data):
    # Demote non-sealed allowlisted IPs that lack an Ed25519 pubkey to pending.
    for row in list(data.get("allowed") or []):
        if _circle_row_is_sealed(row) or _circle_row_has_key(row):
            kept.append(row)
            continue
```

```
# -> pending note: "needs key bind - removed from circle (key required)"
```

`\_read\_vpn\_allowlist` no longer seeds sticky WANs into `allowed`. `\_write\_vpn\_allowlist` always scrubs, then writes sticky /32s only for sealed or key-bound rows (mode 0o600 on JSON).

3.4 Script parity

`ensure-vpn-client-gate.sh` and `ensure-ikev2-peer-acl.sh` share the same rule:

```
def row_is_circle_trusted(row):  
    return row_is_sealed(row) or row_has_key(row)
```

Flint gate treats keyless "allowed" LAN as blocked until scrub:

```
allowed = { ip for row in allowed if is_home_lan(ip) and row.pubkey }  
keyless_allowed = { ip for row in allowed if is_home_lan(ip) and not row.pubkey }
```

keyless + pending -> REJECT to VPS :80,:443 unless enrolled / enroll-unlocked

Live verification (4 Oct): injected keyless 192.168.8.199; peer-acl scrubbed it to pending and Flint REJECT'd it within one timer tick. Six production LAN members (.137/.163/.164/.214/.243/.250) remain - each key-bound.

4. Circle crypto proofs

Authenticator apps (Windows / iPhone / Android) hold a local Ed25519 private key per LAN IP. Mutations send proof headers; the portal verifies:

```
def _verify_ed25519(*, pubkey_b64, message, signature_b64) -> bool:  
    pub = Ed25519PublicKey.from_public_bytes(...)   
    pub.verify(signature_bytes, message.encode("utf-8"))
```

Proof envelope:

```
SM-CIRCLE-V1  
<ts>  
<nonce>  
<ip>  
<METHOD>  
<path>  
<body_sha256>
```

`\_require\_circle\_crypto\_proof` rejects missing headers, skew > CIRCLE_PROOF_MAX_SKEW, unbound IPs, or pubkey mismatch vs the stored bind. Nonces are purged after use (replay resistance within process memory).

Mismatch behavior: wrong private key => signature fail or bound-key mismatch => mutate denied; IP stays pending / out of sticky. Correct key on another device still fails if that IP's bind points at a different pubkey (operator must revoke/rebind).

5. Portal session and client-IP hardening

5.1 Cookies

```
def _cookie_set_header(token: str) -> str:
    return (
        f"{COOKIE_NAME}={token}; Path=/; HttpOnly; Secure; SameSite=Lax; "
        f"Max-Age={int(SESSION_HOURS * 3600)}"
    )
```

Secure+HttpOnly+SameSite=Lax for portal sessions. Grafana SSO uses SameSite=None; Secure for cross-subdomain iframes (higher CSRF surface; Grafana authz is the mitigator).

5.2 Proxy-safe logout keying

```
def request_client_ip(handler):
    peer = normalize(handler.client_address[0])
    if is_loopback_or_link_local(peer):
        # honor X-Real-IP / first X-Forwarded-For only from local proxy
        ...
    return peer # ignore spoofed XFF from direct clients
```

TOTP fail windows / IP jail cannot be reset by forging X-Forwarded-For against the public portal listener.

5.3 Authenticator controls (defaults)

Constant	Default	Role
AUTH_APP_ENROLL_UNLOCK_SECONDS	900	Timed enroll window
AUTH_APP_TOTP_MAX_FAILS	3-8	Failures before logout
AUTH_APP_TOTP_LOCKOUT	300s	Logout duration
AUTH_APP_MAX_DEVICES	8	Cap enrolled devices
SSH_PANEL_UNLOCK_SECONDS	300	Extra unlock for SSH / circle UI

Enrollment is locked by default. Trust-circle UI nests under Security -> VPS login / SSH unlock. Security panel now shows Key confirmed per circle row.

6. Edge hardening and VPN-only admin

Idempotent scripts under `portal/scripts/security/` encode packet policy with BEGIN/END markers:

Script | Purpose

harden-ssh-port-rate-cap.sh | UFW limit :22, connlimit, MaxAuthTries 3
harden-vpn-ports-rate-cap.sh | Optional IKEv2/WG/VPN caps (default off)
harden-http-ports-conn-cap.sh | Optional 80/443 connlimit (default off)
harden-portal-5002-vpn-only.sh | Panel direct port not public
harden-wg-easy-ui-vpn-only.sh | WG admin UI VPN-scoped
harden-smb / nas-gateways-vpn-only | File planes VPN-scoped
harden-deny-campus-egress.sh | Campus WAN deny assistance
harden-secret-perms.sh | 00600 on allowlist / sticky / 2FA files
loosen-*-ports-*.sh | Emergency rollback companions

Caddy `@vpn\_clients` gates proxmox / plex / router hostnames to sticky + VPN pools. `@denied\_wan` blocks campus shared egress from those host blocks (keys.vpstruelord.com / auth-app paths intentionally omit campus deny so phones can enroll from school Wi-Fi when LAN PBR is unavailable).

7. USB key vault

Threat: SSH private keys always-decrypted under ~/.ssh.

Artifact | Role

new-sm-usb-key-vault.sh | 256MB LUKS2 on Norelsys USB; refuse Elements
new-sm-usb-ssh-key.sh | ed25519 inside vault
mount / dismount-sm-usb-key-vault.sh | Unlock window + optional ssh-add TTL
stego-text-in-png.py | Recovery hint (not crypto)

Limits: unlocked keys are software-readable; stego on same stick is convenience; WebAuthn/YubiKey still future work.

8. Threat scenarios mapped to controls

D.1 Internet scanner on :22

UFW limit + connlimit + MaxAuthTries 3. Residual: slow distributed scans.

D.2 Stolen portal password

Pending login + Authenticator TOTP + Secure cookie. Residual: stolen live session until expiry.

D.3 Unapproved friend on home Wi-Fi

Flint SM-LAN-CIRCLE REJECT pending/keyless to VPS :80/:443; Authenticator must approve with key. Residual: other LAN services need host firewalls.

D.4 VPN client not in circle

Guest DNS; no sticky ACL; no key bind. Residual: raw-IP if routing is broad.

D.5 Approve without key / sticky resurrection

Approve rejected; scrub demotes; sticky seed without key removed. Verified live with .199 inject.

D.6 Key mismatch across devices

Bound pubkey check + signature verify fail closed. Operator revokes/rebinds IP.

D.7 Disk theft of Proxmox USB

LUKS2 image; passphrase off-disk. Residual: stego+method knowledge.

9. Findings summary

Strengths

1. VPN-first exposure with policy-as-code hardeners.
2. Layered circle: DNS guest + Caddy ACL + Flint pre-NAT + Ed25519 bind.
3. Approve/scrub/sticky/gate scripts agree on key-required policy.
4. Proxy-safe request_client_ip; Secure cookies; 0o600 state files.
5. Campus WAN hard-deny; sealed router WAN cannot be casually revoked.

Weaknesses / follow-ups

ID	Sev	Issue	Direction
W1	Med	VPN/HTTP rate caps default off	Runbook to flip loose under abuse
W2	Med	No WebAuthn yet	Passkey step-up; TOTP backup
W3	Med	Distributed circle state	Drift metrics sticky vs allowlist vs Caddy
W4	Med	In-memory nonces / lockouts	Persist or document restart=reset
W5	Med	Enroll-unlock opens all pending LAN	Narrow to registering device
W6	Low	USB vault != HSM	YubiKey sk-ssh-ed25519 path
W7	Low	Guest DNS bypassable	Document; tighten Flint forwards
W8	Info	Large server.py monolith	Split auth / vpn modules

10. Conclusions and checklist

Key-required membership closes the largest remaining circle gap: IP approval without cryptographic device identity. Combined with prior edge hardeners, Authenticator lockouts, and Flint pre-NAT gating, opportunistic joiners (home Wi-Fi guests, campus NAT, sticky leftovers) cannot remain in the admin plane without an Authenticator-held private key.

Operator checklist

1. Approve only from enrolled Authenticator (creates/binds Ed25519).

2. Confirm Security panel Key confirmed for every Allowed row.
 3. After SSH on Proxmox: dismount USB vault.
 4. Under flood: VPN_RATE_CAP_MODE=loose / HTTP_RATE_CAP_MODE=loose.
 5. Periodically run peer-acl and confirm sticky = key-bound set.
 6. Keep panel JSON modes 600 via harden-secret-perms.sh.
 7. Never leave enroll-unlock open after phone setup.
-

Appendix A - Key file index

Path | Why

portal/server.py | Sessions, circle crypto, scrub, approve, Caddy snippets
portal/static/sm-circle-crypto.js | Client Ed25519 + proof headers
portal/static/index.html | Security UI Key confirmed column
portal/scripts/ikev2/ensure-vpn-client-gate.sh | Guest DNS + key scrub
portal/scripts/ikev2/ensure-ikev2-peer-acl.sh | Caddy ACL sync; no sticky seed
portal/scripts/ikev2/ensure-lan-circle-flint-gate.sh | Pre-NAT keyless/pending block
portal/scripts/security/harden-*.sh | Edge policy as code
portal/scripts/security/usb-key-vault/* | LUKS SSH vault
/opt/servermanager/panel/vpn-allowlist.json | Circle source of truth
/opt/servermanager/panel/caddy-sticky-vpn-ips.txt | Sticky key-bound /32s

Appendix B - Scorecard (4 Oct)

Area | Score | Comment

Edge exposure | 9 | VPN-first; SSH capped
Portal AuthN/Z | 8 | Session+TOTP; WebAuthn missing
Circle correctness | 9 | Key-bound + scrub verified live
Secret / key handling | 7 | USB LUKS; not HSM
Operability | 9 | Idempotent scripts + loosen
Observability | 5 | Little drift alerting
Documentation | 8 | This review + code comments

Composite ~8.1/10 for the intended threat model (up from ~7.8 after key-required enforcement).

Appendix C - Extended code excerpts

C.1 Sticky write (only sealed / key-bound)

portal/server.py _write_vpn_allowlist

```
data, _ = _ensure_sealed_vpn_allowlist(data)
data, _ = _scrub_allowlist_require_circle_keys(data)
...
```

```
os.chmod(VPN_ALLOWLIST_PATH, 0o600)
lines = [
    "# Key-bound only (except sealed router WAN). No blanket 192.168.8.0/24.",
]
for row in payload["allowed"]:
    ip = _normalize_vpn_ip(row.get("ip", ""))
    if not ip or not (_is_public_ipv4(ip) or _is_home_lan_ipv4(ip)):
        continue
    if _circle_row_is_sealed(row) or _circle_row_has_key(row):
        lines.append(f"{ip}/32")
STICKY_VPN_IPS_PATH.write_text("\n".join(lines) + "\n")
```

C.2 Client-gate trust set

ensure-vpn-client-gate.sh

```
allowed_ips = {
    normalize_ip(x.get("ip", ""))
    for x in data["allowed"]
    if isinstance(x, dict)
    and normalize_ip(x.get("ip", ""))
    and row_is_circle_trusted(x)
}
```

trusted VIP => AdGuard DNS + host INPUT; else guest DNS

C.3 Peer ACL: no sticky seed

ensure-ikev2-peer-acl.sh ensure_allowlist_seeded

sticky arg is ignored for seeding - kept for call-site compatibility.

```
_ = sticky
```

Demote non-sealed keyless rows to pending (do not sticky-seed them back).

```
for ip, row in list(by_ip.items()):
    if ip in sealed_ips or row_is_circle_trusted(row):
        continue
    del by_ip[ip]
    # pending note: needs key bind - removed from circle (key required)
```

C.4 Proof require (bind check)

portal/server.py _require_circle_crypto_proof

```
if require_existing_bind:
    bound = _circle_pubkey_for_ip(ip_h)
    if not bound:
        raise ValueError("No circle key bound to this IP")
    if bound != pub:
        raise ValueError(
            "Circle public key does not match the key bound to this IP"
        )
if abs(now - ts) > max(30, CIRCLE_PROOF_MAX_SKEW):
    raise ValueError("circle proof timestamp skew too large")
```

C.5 Authenticator client bind (sm-circle-crypto.js)

Client stores Ed25519 per LAN IP in IndexedDB / secure storage

On approve: sign SM-CIRCLE-V1 envelope; POST with pubkey + X-SM-Circle-*

Server stores pubkey on approve; subsequent mutates require matching proof

Appendix D - Suggested next hardening sprint

1. WebAuthn / passkey for Security unlock (TOTP fallback).
2. Alert when sticky set diverges from key-bound allowlist.
3. Auto-enable VPN_RATE_CAP_MODE=loose after N SSH fails / min.
4. Narrow enroll-unlock Flint exemption to the registering IP only.
5. Split server.py auth + vpn-allowlist modules for review surface.
6. YubiKey sk-ssh-ed25519 as upgrade from USB LUKS.
7. Smoke test: keyless inject demoted; pending blocked; key-bound reachable.

Appendix E - Methodology

Reviewed repository state on 2026-10-04 on branch cursor/keys-home-wifi-enroll-a9a6: portal/server.py circle helpers, ikev2 gate scripts, hardeners, Authenticator static apps. Deployed to live VPS and confirmed scrub+Flint REJECT on a synthetic keyless LAN IP. Design-and-code review, not a penetration test.

Also cross-checked: campus @denied_wan on public host blocks; keys/auth-app host blocks omit campus deny so phones can reach enrollment from school Wi-Fi; LAN approve continues via OpenVPN PBR as 10.9.0.2 when home Wi-Fi is used.

Document control: Generated 2026-10-04 via portal/docs/build_security_review_pdf.py; supersedes 2026-10-03 review.

End of review.